

Penugasan Modul 2

Disusun Oleh :

Nama Kelompok 8

Afnan Yazid Pradana

Kelvin Febrianto

Kurniawan Saputra

Rishfan Mailizar

Divisi Cyber Security Ethical Hacker

Penugasan Modul 2: Scanning & Vulnerability Analysis (Hard Mode / Advanced Level)

Skenario Praktik (*Black-Box Assessment*) Pada tingkat lanjutan ini, Anda tidak akan diberikan Alamat IP target secara langsung. Target adalah sebuah mesin virtual rentan (seperti Metasploitable) yang tersembunyi di dalam jaringan *subnet* lab internal terisolasi (misalnya 192.168.1.0/24).

Sebagai *Ethical Hacker*, Anda harus mengasumsikan bahwa jaringan ini diawasi oleh *Intrusion Detection System* (IDS). Misi Anda adalah menemukan target, melakukan pemindaian tanpa memicu terlalu banyak kebisingan jaringan (*stealth*), dan menyusun laporan kerentanan berstandar industri.

Daftar Tugas (*Deliverables*)

1. Misi *Host Discovery & Pemindaian Stealth* (Evasion)

Alih-alih langsung memindai *port*, Anda harus memetakan jaringan untuk menemukan IP target yang hidup terlebih dahulu, lalu melakukan pemindaian yang dimodifikasi untuk menghindari deteksi *firewall*.

• Tugas Teknis:

- Gunakan Nmap untuk melakukan *Ping Sweep* (-sn) pada *subnet* lab untuk menemukan IP target.

Jawaban : Dengan perintah tersebut, Nmap akan melakukan ping sweep ke seluruh rentang IP 192.168.1.1 sampai 192.168.1.255

```

└─$ sudo nmap -sn 192.168.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-08 15:41 +0700
Nmap scan report for 192.168.1.20
Host is up (0.00041s latency).
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Nmap scan report for 192.168.1.10
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 2.05 seconds

```

- Lakukan *port scanning* TCP dan UDP menggunakan teknik fragmentasi paket (-f) atau modifikasi waktu (-T2 / Polite) untuk mengelabui deteksi jaringan.

Jawaban: Pemindaian port UDP dilakukan dengan menggunakan parameter modifikasi waktu -T2 (Polite) guna memperlambat laju pengiriman paket agar tidak memicu sistem deteksi intrusi (IDS/Firewall).

```

└─$ sudo nmap -sU -f -T2 --top-port 50 192.168.1.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-10 14:42 +0700
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan
UDP Scan Timing: About 6.00% done; ETC: 14:42 (0:00:31 remaining)
Nmap scan report for 192.168.1.20
Host is up (0.00058s latency).
Not shown: 44 closed udp ports (port-unreach)
PORT      STATE      SERVICE
53/udp    open       domain
69/udp    open|filtered tftp
111/udp   open       rpcbind
137/udp   open       netbios-ns
138/udp   open|filtered netbios-dgm
2049/udp  open       nfs
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 45.23 seconds

```

lalu pemindaian port tcp dilakukan dengan menggunakan parameter modifikasi waktu -T2 (Polite) guna memperlambat laju pengiriman paket agar tidak memicu sistem deteksi intrusi (IDS/Firewall).

```

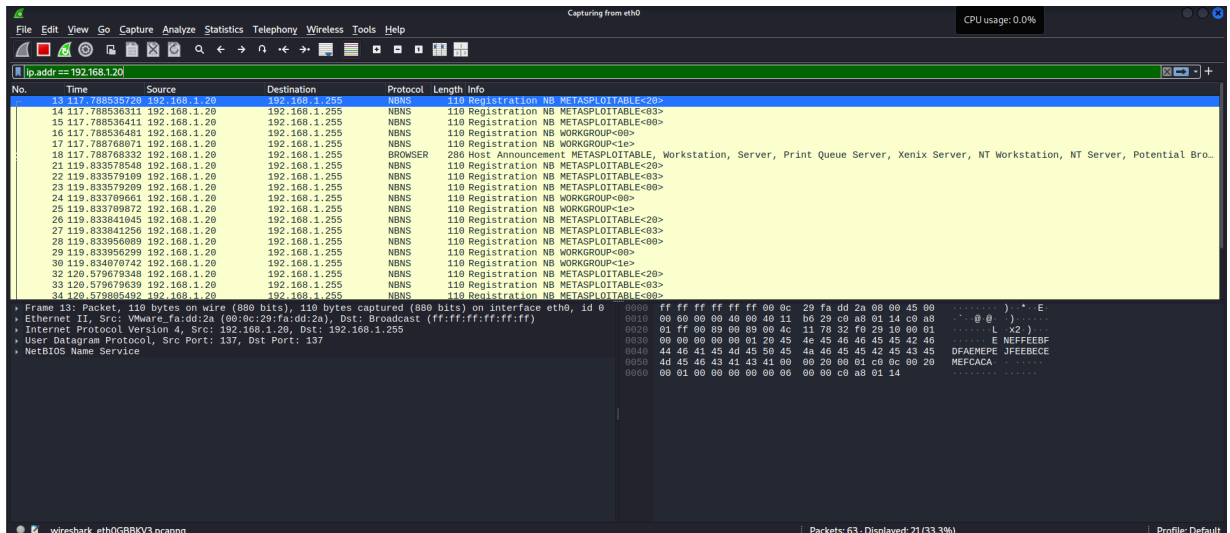
└─$ sudo nmap -sS -f -T2 --top-port 100 192.168.1.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-10 14:39 +0700
Nmap scan report for 192.168.1.20
Host is up (0.00048s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE      SERVICE
21/tcp    open       ftp
22/tcp    open       ssh
23/tcp    open       telnet
25/tcp    open       smtp
53/tcp    open       domain
80/tcp    open       http
111/tcp   open       rpcbind
139/tcp   open       netbios-ssn
445/tcp   open       microsoft-ds
513/tcp   open       login
514/tcp   open       shell
2049/tcp  open       nfs
2121/tcp  open       ccproxy-ftp
3306/tcp  open       mysql
5432/tcp  open       postgresql
5900/tcp  open       vnc
6000/tcp  open       X11
8009/tcp  open       ajp13
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 40.64 seconds

```

- o Jalankan **Wireshark** di latar belakang saat pemindaian Nmap berlangsung.

Jawaban: Jangan gunakan Wireshark di Windows. Buka terminal di **Kali Linux**, lalu jalankan Wireshark secara langsung dari cmd yaitu sudo wireshark & lalu pilih eth0. Nah berhasil merekam lalu lintas pemindaian Nmap secara langsung dari Kali Linux (192.168.1.10) ke mesin target Metasploitable (192.168.1.20). Terlihat jelas bahwa pemindaian Nmap di Wireshark telah berjalan dan berhasil.



Output Laporan: Lampirkan tangkapan layar IP yang ditemukan, *output* Nmap, dan tangkapan layar Wireshark yang menunjukkan paket terfragmentasi atau jeda waktu antar paket.

2. Misi *Deep Fingerprinting & Manual Banner Grabbing* Nmap `-sV` terkadang memberikan hasil yang tidak akurat pada *port* yang disamarkan. Anda harus melakukan validasi manual.

• Tugas Teknis:

- o Gunakan Nmap dengan opsi deteksi versi agresif (`-sV --version-all`).

Jawaban : Perintah ini meminta Nmap memindai Port 21 (FTP), 22 (SSH), dan 80 (HTTP) pada IP target 192.168.1.20 dengan intensitas deteksi versi tertinggi (`--version-all`).

```
$ sudo nmap -sV --version-all -p 21,22,80 192.168.1.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-10 14:46 +0700
Nmap scan report for 192.168.1.20
Host is up (0.00051s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.70 seconds
```

Gambar 2.1 Output Pemindaian Nmap Agresif

Jawaban: Setelah koneksi terbuka, pengiriman perintah head secara manual meminta server web merespons dengan struktur halaman utama. Server mengirimkan balasan HTML yang memuat judul <title>Metasploitable2 - Linux</title> serta daftar direktori web terpasang (seperti /dvwa/, /phpMyAdmin/, dll.), membuktikan bahwa target adalah VM Metasploitable 2 yang aktif di port HTTP.

• **Output Laporan:** Tabel komparasi yang membandingkan hasil tebakan versi dari Nmap

No.	Port / Protokol	Versi Tebakan Nmap (-sV --version-all)	Teks Banner Asli (Manual via Netcat)	Status Validasi
1	21 / TCP (FTP)	vsftpd 2.3.4	220 (vsFTPd 2.3.4)	Valid / Akurat
2	22 / TCP (SSH)	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)	SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1	Valid / Akurat
3	80 / TCP (HTTP)	Apache httpd 2.2.8 ((Ubuntu) DAV/2)	Metasploitable2 - Linux (<i>Banner HTML awal</i>)	Valid / Akurat

dengan teks *banner* asli yang Anda dapatkan secara manual via Netcat. 3

D. Analisis & Pembahasan

1. Layanan FTP (Port 21):

- **Nmap:** Memprediksi layanan yang berjalan adalah vsftpd 2.3.4.
- **Netcat:** Perintah nc -vn 192.168.1.20 21 menghasilkan respons awal dari server dengan banner 220 (vsFTPd 2.3.4). Hasil manual mengonfirmasi keakuratan tebakan Nmap.

2. Layanan SSH (Port 22):

- **Nmap:** Memprediksi layanan OpenSSH 4.7p1 Debian 8ubuntu1.
- **Netcat:** Perintah nc -vn 192.168.1.20 22 merespons dengan banner SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1. Data versi dan sistem operasi identik dengan pindaian Nmap.

3. Layanan HTTP (Port 80):

- **Nmap:** Memprediksi server web Apache httpd 2.2.8 ((Ubuntu) DAV/2).
- **Netcat:** Perintah nc -vn 192.168.1.20 80 yang dilanjutkan dengan perintah head menampilkan tag judul HTML <title>Metasploitable2 - Linux</title> serta daftar direktori web (seperti /dvwa/, /phpMyAdmin/, dll.), membuktikan bahwa

target adalah VM Metasploitable 2 yang aktif di port HTTP.

3. Misi *Vulnerability Scanning Berbasis Engine*

Tinggalkan pemindaian dasar dan beralih ke analisis kerentanan otomatis menggunakan konfigurasi tingkat lanjut.

• Tugas Teknis:

- Jalankan pemindai kerentanan **Nessus** pada IP target (pastikan Anda mengonfigurasi *Basic Network Scan* secara lengkap).

Jawaban:

Filter

Search Vulnerabilities

65 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8	7.9	0.9927	Apache Tomcat AJP Connector Request Injecti...	Web Servers	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
HIGH	7.5			NFS Shares World Readable	RPC	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	28	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	

Host Details

IP:

192.168.126.129

MAC:

00:0C:29:A5:69:9A

OS:

Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

Start:

Today at 6:11 AM

End:

Today at 6:43 AM

Elapsed:

32 minutes

KB:

[Download](#)

Auth:

Fail

Vulnerabilities

Critical

High

Medium

Low

Info

Tangkapan layar di atas menampilkan ringkasan hasil pemindaian kerentanan (Basic Network Scan) yang dilakukan menggunakan Nessus terhadap host target. Pemindaian mengidentifikasi total 65 kerentanan pada mesin target dengan detail sebagai berikut:

- IP Target: `192.168.126.129`
- MAC Address: `00:0C:29:A5:69:9A`
- Sistem Operasi Terdeteksi: `Linux Kernel 2.6 on Ubuntu 8.04 (hardy)`
- Durasi Pemindaian: 32 menit

Rincian Temuan Kerentanan Tingkat High & Critical

1. Canonical Ubuntu Linux SEoL (8.04.x)

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)		Plugin Details					
Description According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider. Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities. Solution Upgrade to a version of Canonical Ubuntu Linux that is currently supported. See Also http://www.nessus.org/u/73bdb2d2e Output <pre>OS : Ubuntu Linux 8.04 Security End of Life : May 9, 2013 Time since Security End of Life (Est.) : >= 13 years</pre> To see debug logs, please visit individual host <table><thead><tr><th>Port</th><th>Hosts</th></tr></thead><tbody><tr><td>80 / http / www</td><td>192.168.126.129</td></tr></tbody></table>		Port	Hosts	80 / http / www	192.168.126.129	Risk Information Risk Factor: Critical CVSS v3.0 Base Score: 10.0 CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/CH:H/HA:H CVSS v2.0 Base Score: 10.0 CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/IC:C/A:C Vulnerability Information CPE: cpe:/o:canonical:ubuntu_linux	
Port	Hosts						
80 / http / www	192.168.126.129						

Keterangan: Sistem operasi sudah mencapai status *End of Life* (EoL) dan tidak lagi menerima pembaruan keamanan resmi.

Hosts 1
Vulnerabilities 65
Remediations 2
History 1

CRITICAL

VNC Server 'password' Password

< >

Plugin Details

↗

Description

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution

Secure the VNC service with a strong password.

Output

Nessus logged in using a password of "password".

To see debug logs, please visit individual host

Port ▲	Hosts
5900 /tcp /vnc	192.168.126.129

Risk Information

Risk Factor: Critical

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

Default Account: true

Keterangan: Layanan VNC menggunakan kata sandi bawaan/lemah yang sangat mudah ditebak.

Critical

Apache Tomcat AJP Connector Request Injection (Ghostcat)

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

See Also

<http://www.nessus.org/u?8ebe6246>
<http://www.nessus.org/u?4e287adb>
<http://www.nessus.org/u?fbc3d54e>
<https://access.redhat.com/security/pove/CVE-2020-1745>
<https://access.redhat.com/solutions/4851231>
<http://www.nessus.org/u?dd218234>
<http://www.nessus.org/u?dd772531>
<http://www.nessus.org/u?2a01deb1>
<http://www.nessus.org/u?3b5af27e>
<http://www.nessus.org/u?9dab109f>
<http://www.nessus.org/u?5eafc70>

Plugin Details

Severity:	Critical
ID:	134862
Version:	1.63
Type:	remote
Family:	Web Servers
Published:	March 24, 2020
Modified:	March 23, 2026

VPR Key Drivers

Threat Recency:	No recorded events
Threat Intensity:	Very Low
Exploit Code Maturity:	High
Age of Vuln:	730 days +
Product Coverage:	Very High
CVSSV3 Impact Score:	5.9
Threat Sources:	No recorded events

Risk Information

Vulnerability Priority Rating (VPR):	7.9
Exploit Prediction Scoring System (EPSS):	0.9927
Risk Factor:	High
CVSS v3.0 Base Score:	8.8
CVSS v2.0 Vector:	CVSS:2.0/AV:N/AC:L/PR:N/UI:N/AU:C/E:P/SL:C/CF:S/I:CR/CR:X

Output

Messus was able to exploit the issue using the following request :

ms/my-scans : 02 02 00 08 48 54 50 2F 31 2E 31 00 00 0F 2FHTTP/1.1....//

Keterangan: Celah pada protokol AJP yang memungkinkan pembacaan file arbitrer atau eksekusi kode pada server web.

4. SSL Version 2 and 3 Protocol Detection

CRITICAL

SSL Version 2 and 3 Protocol Detection

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:

- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.

An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.

Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.

NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.

Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also

<https://www.schwerer.com/academic/paperfiles/paper-ssl.pdf>

<http://www.nessus.org/issue27495>

<http://www.nessus.org/issue247c4540>

<https://www.openssl.org/~bodo/ssl-poodle.pdf>

Plugin Details

Severity: Critical

ID: 20007

Version: 1.35

Type: remote

Family: Service detection

Published: October 12, 2005

Modified: April 13, 2026

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

In the news: true

Severity: CRITICAL (CVSS: 9.8)

Kategori: Service detection

Keterangan: Penggunaan enkripsi SSL versi lama yang rentan terhadap serangan Man-in-the-Middle (MitM) seperti POODLE.

5. Bind Shell Backdoor Detection

critical

Bind Shell Backdoor Detection

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Output

Nessus was able to execute the command "id" using the following request :

This produced the following truncated output (limited to 10 lines) :

```
----- snip -----
root@metasploitables:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitables:/#
----- snip -----
```

To see debug logs, please visit individual host

Port

Hosts

1524/http/wild_shell 192.168.126.129

Plugin Details

Severity: Critical

ID: 51988

Version: 1.10

Type: remote

Family: Backdoors

Published: February 15, 2011

Modified: April 11, 2022

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Severity: CRITICAL (CVSS: 9.8)

Kategori: Backdoors

Keterangan: Terdeteksi adanya *backdoor* aktif yang membuka akses shell langsung tanpa otentikasi.

6. Samba Badlock Vulnerability

Severity: High
ID: 90509
Version: 1.9
Type: remote
Family: General
Published: April 13, 2016
Modified: November 17, 2025

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: Unproven
Age of Vuln: 730 days +
Product Coverage: Very High
CVSSv3 Impact Score: 5.9
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 4.9
Exploit Prediction Scoring System (EPSS): 0.3693
Risk Factor: Medium
CVSS v3.0 Base Score: 7.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/H:PR/N/UI:R/

Description
The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (LSA) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution
Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

See Also
<https://www.samba.org/samba/security/CVE-2016-2118.html>

Output
Nessus detected that the Samba Badlock patch has not been applied.
To see debug logs, please visit individual host

Port	Hosts
445/tcp/cifs	192.168.126.129

Severity: HIGH (CVSS: 7.5)

Kategori: General

Keterangan: Kerentanan pada protokol SAMBA yang memungkinkan manipulasi lalu lintas otentikasi.

7. NFS Shares World Readable

Severity: High
ID: 42256
Version: 1.12
Type: remote
Family: RPC
Published: October 26, 2009
Modified: February 21, 2024

Risk Information

Risk Factor: Medium
CVSS v3.0 Base Score: 7.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector: CVSS2:AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information
Vulnerability Pub Date: January 1, 1985

Description
The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

Solution
Place the appropriate restrictions on all NFS shares.

See Also
<http://www.fdot.org/HOWTO/NFS-HOWTO/security.html>

Output
The following shares have no access restrictions :
/ *

To see debug logs, please visit individual host

Port	Hosts
2049/tcp/rpc.nfs	192.168.126.129

Severity: HIGH (CVSS: 7.5)

Kategori: RPC

Keterangan: Direktori Network File System (NFS) dibagikan secara terbuka tanpa pembatasan hak akses yang memadai.

- o Sebagai *backup* dan komparasi, gunakan *Nmap Scripting Engine* (NSE) dengan kategori yang lebih spesifik dan agresif (contoh: `nmap --script vuln,exploit,auth -p [Port] [IP]`).

Jawaban:

Vulnerability scanning dilakukan menggunakan Nmap Scripting Engine (NSE) dengan perintah `nmap -sV --script "vuln,exploit,auth"` pada beberapa port layanan yang telah diidentifikasi sebelumnya. Pemindaian ini bertujuan untuk melakukan identifikasi versi layanan sekaligus mendeteksi indikasi kerentanan, informasi eksploitasi, dan konfigurasi autentikasi pada target Metasploitable 2.

```

25/tcp open smtp Postfix smtpd
| smtp-vuln-cve2010-4344:
|   The SMTP server is not Exim: NOT VULNERABLE
|   smtp-enum-users:
|     Method RCPT returned a unhandled status code.
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
| http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-dombased-xss: Couldn't find any DOM based XSS.
| http-stored-xss: Couldn't find any stored XSS vulnerabilities.
vulners:
cpe:/a:apache:http_server:2.2.8:
SSV:69341 10.0 https://vulners.com/seebug/SSV:69341 *EXPLOIT*
SSV:19282 10.0 https://vulners.com/seebug/SSV:19282 *EXPLOIT*
SSV:19236 10.0 https://vulners.com/seebug/SSV:19236 *EXPLOIT*
SSV:11999 10.0 https://vulners.com/seebug/SSV:11999 *EXPLOIT*
PACKETSTORM:86964 10.0 https://vulners.com/packetstorm/PACKETSTORM:86964 *EXPLOIT*
PACKETSTORM:180533 10.0 https://vulners.com/packetstorm/PACKETSTORM:180533 *EXPLOIT*
MSF-AUXILIARY-DOS-HTTP-APACHE_MOD_ISAPI- 10.0 https://vulners.com/metasploit/MSF-AUXILIARY-DOS-HTTP-APACHE_MOD_ISAPI- *EXPLOIT*
HTTPD:E74B6F3660D13C4DD05DF3A83EA61631 10.0 https://vulners.com/httpd/HTTPD:E74B6F3660D13C4DD05DF3A83EA61631
HTTPD:81180E4E634DECC978414601684A949 10.0 https://vulners.com/httpd/HTTPD:81180E4E634DECC978414601684A949
EXPLOITPACK:30ED468EC8B05871B2CB93825A852880 10.0 https://vulners.com/exploitpack/EXPLOITPACK:30ED468EC8B05871B2CB93825A852880 *EXPLOIT*
EDB-ID:14288 10.0 https://vulners.com/exploitdb/EDB-ID:14288 *EXPLOIT*
EDB-ID:11650 10.0 https://vulners.com/exploitdb/EDB-ID:11650 *EXPLOIT*
CVE-2010-0425 10.0 https://vulners.com/cve/CVE-2010-0425
A418DBAB-C86F-56F2-B9E8-709503C4D553 10.0 https://vulners.com/githubexploit/A418DBAB-C86F-56F2-B9E8-709503C4D553 *EXPLOIT*
3E6B4008-776F-581F-9BA5-589CD2A5A351 10.0 https://vulners.com/gitex/3E6B4008-776F-581F-9BA5-589CD2A5A351 *EXPLOIT*
PACKETSTORM:171631 9.8 https://vulners.com/packetstorm/PACKETSTORM:171631 *EXPLOIT*
HTTPD:E69E9574251973D5AF93FA9D084997FC1 9.8 https://vulners.com/httpd/HTTPD:E69E9574251973D5AF93FA9D084997FC1
HTTPD:E162D3AE025639FE2A89D5AF40ABF2F 9.8 https://vulners.com/httpd/HTTPD:E162D3AE025639FE2A89D5AF40ABF2F
HTTPD:C872933AA965A86DA3E2C9172FFC1569 9.8 https://vulners.com/httpd/HTTPD:C872933AA965A86DA3E2C9172FFC1569
HTTPD:A18BCE110E0777FBFA469DAF600B9293 9.8 https://vulners.com/httpd/HTTPD:A18BCE110E0777FBFA469DAF600B9293
HTTPD:A09F9CEB087C39EDA0A480FEAF4FE9D 9.8 https://vulners.com/httpd/HTTPD:A09F9CEB087C39EDA0A480FEAF4FE9D
HTTPD:9F5406E0FA0B007A0A4C9C92EF9813B 9.8 https://vulners.com/httpd/HTTPD:9F5406E0FA0B007A0A4C9C92EF9813B
HTTPD:9BCBE3C14201AFC4B0F36F15CB4BC0F8 9.8 https://vulners.com/httpd/HTTPD:9BCBE3C14201AFC4B0F36F15CB4BC0F8
HTTPD:2BE0832A6A8E7CC52906D0A4FE0448E 9.8 https://vulners.com/httpd/HTTPD:2BE0832A6A8E7CC52906D0A4FE0448E
EDB-ID:51193 9.8 https://vulners.com/exploitdb/EDB-ID:51193 *EXPLOIT*
EDB-ID:10579 9.8 https://vulners.com/exploitdb/EDB-ID:10579 *EXPLOIT*
EDB-ID:10071 9.8 https://vulners.com/exploitdb/EDB-ID:10071 *EXPLOIT*
ECC3E825-EE29-59D3-BE28-1B300B15940E 9.8 https://vulners.com/githubexploit/ECC3E825-EE29-59D3-BE28-1B300B15940E *EXPLOIT*
D5084051-C8D9-5CBA-BC26-ACF2E33F8E52 9.8 https://vulners.com/githubexploit/D5084051-C8D9-5CBA-BC26-ACF2E33F8E52 *EXPLOIT*
CVE-2026-28780 9.8 https://vulners.com/cve/CVE-2026-28780
CVE-2024-38476 9.8 https://vulners.com/cve/CVE-2024-38476
CVE-2022-31813 9.8 https://vulners.com/cve/CVE-2022-31813
CVE-2022-22720 9.8 https://vulners.com/cve/CVE-2022-22720

```

Berdasarkan hasil pemindaian, ditemukan beberapa layanan aktif, di antaranya SMTP pada port 25 dan HTTP Apache pada port 80. Pada layanan SMTP, Nmap berhasil mengidentifikasi Postfix SMTP daemon. Script `smtp-vuln-cve2010-4344` menunjukkan bahwa layanan SMTP tersebut tidak menggunakan Exim sehingga dinyatakan NOT VULNERABLE terhadap CVE-2010-4344. Selain itu, script `smtp-enum-users` mencoba melakukan enumerasi pengguna menggunakan metode RCPT, namun server memberikan respons yang tidak dapat diproses oleh script.

Temuan yang paling signifikan terdapat pada port 80/tcp, yang menjalankan Apache HTTP Server versi 2.2.8 pada Ubuntu dengan DAV/2. Hasil script NSE menunjukkan bahwa versi Apache tersebut memiliki sejumlah referensi kerentanan dan exploit berdasarkan pencocokan informasi versi layanan dengan database Vulners. Beberapa referensi memiliki skor tingkat keparahan hingga 10.0 dan 9.8, yang mengindikasikan potensi risiko sangat tinggi apabila kerentanan tersebut benar-benar berlaku pada konfigurasi target.

Namun, hasil dari script `vulners` perlu diperlakukan sebagai indikasi awal dan bukan bukti eksploitabilitas langsung. Pencocokan dilakukan terutama berdasarkan versi software atau CPE, sehingga daftar CVE yang ditampilkan dapat mencakup kerentanan yang relevan dengan versi Apache secara umum tetapi belum tentu dapat dieksploitasi pada konfigurasi spesifik target. Oleh karena itu, diperlukan validasi lebih lanjut menggunakan vulnerability scanner seperti Nessus atau pemeriksaan manual terhadap CVE yang paling relevan.

Pada pengujian kerentanan aplikasi web, script `http-dombased-xss` tidak menemukan indikasi kerentanan DOM-based Cross-Site Scripting, sedangkan script `http-stored-xss` juga tidak menemukan kerentanan Stored XSS pada target yang diuji. Sementara itu, script `http-vuln-cve2017-1001000` mengalami kegagalan eksekusi sehingga tidak dapat digunakan untuk menyimpulkan apakah target rentan atau tidak terhadap CVE tersebut.

Secara keseluruhan, hasil pemindaian NSE menunjukkan bahwa Apache HTTP Server 2.2.8 pada port 80 merupakan layanan dengan tingkat risiko paling tinggi dari hasil scan yang ditampilkan. Sementara layanan SMTP Postfix tidak teridentifikasi rentan terhadap CVE-2010-4344 yang diuji. Hasil ini menunjukkan pentingnya melakukan validasi lanjutan karena Nmap NSE mampu memberikan indikasi kerentanan berdasarkan script dan fingerprinting versi, tetapi tidak semua referensi CVE atau exploit yang muncul dapat langsung dianggap sebagai kerentanan yang telah terbukti.

- **Output Laporan:** Ekspor ringkasan kerentanan tingkat *High* dan *Critical* dari Nessus, serta tangkapan layar *output* NSE Nmap.

4. Misi Validasi *False Positive* & Perhitungan CVSS v3.1 Alat otomatis pasti akan menghasilkan *false positive* (alarm palsu). Anda harus membuktikan bahwa kerentanan tersebut eksis sebelum melaporkannya.

• **Tugas Teknis:**

- Pilih satu kerentanan *Critical* atau *High* dari hasil Nessus (misal: *Anonymous FTP Allowed* atau direktori web yang terbuka).

Jawaban : Untuk memastikan hasil pemindaian bukan merupakan *false positive*, dilakukan eksploitasi dan interaksi manual terhadap kerentanan **Anonymous FTP Allowed** pada IP 192.168.1.20.

- **Perintah:** ftp 192.168.1.20
- **Username:** anonymous
- **Password:** (kosong / tekan Enter)
- **Hasil Eksploitasi:** Server merespons dengan 230 Login successful dan mengizinkan perintah eksekusi direktori (ls), membuktikan bahwa celah keamanan tersebut valid (*True Positive*).

```
└─$ ftp 192.168.1.20
Connected to 192.168.1.20.
220 (vsFTPd 2.3.4)
Name (192.168.1.20:kurniawan): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||34977|).
150 Here comes the directory listing.
226 Directory send OK.
ftp>
ftp> □
```

- Buktikan bahwa celah tersebut valid dengan melakukan interaksi manual (contoh: mencoba masuk ke FTP menggunakan *user* anonymous dan melampirkan tangkapan layar akses yang berhasil).

Jawaban : Menunjukkan proses login FTP menggunakan kredensial **anonymous** tanpa *password*, hingga berhasil mendapatkan hak akses dengan balasan 230 Login successful serta pengujian akses perintah **ls**.

```

$ ftp 192.168.1.20
Connected to 192.168.1.20.
220 (vsFTPd 2.3.4)
Name (192.168.1.20:kurniawan): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||34977|).
150 Here comes the directory listing.
226 Directory send OK.
ftp>
ftp>

```

- Berikan skor manual menggunakan kalkulator *Common Vulnerability Scoring System* (CVSS v3.1) untuk menentukan *Risk Rating*.

Jawaban :

Nama Kerentanan: Anonymous FTP Access Allowed

Base Score: 7.5 (HIGH)

CVSS v3.1 Vector String: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

The screenshot shows the CVSS v3.1 calculator interface. The Base Score is 7.5 (High). The calculator is configured with the following settings:

- Attack Vector (AV):** Network (N)
- Attack Complexity (AC):** Low (L)
- Privileges Required (PR):** None (N)
- User Interaction (UI):** None (N)
- Scope (S):** Unchanged (U)
- Confidentiality (C):** High (H)
- Integrity (I):** None (N)
- Availability (A):** None (N)

The resulting Vector String is: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

- **Output Laporan:** Bukti validasi manual (*screenshot*) dan perhitungan skor CVSS v3.1 lengkap dengan vektornya (contoh: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N).

5. Misi *Enterprise-Grade Mitigation Matrix* Susun hasil laporan celah keamanan (*vuln report*) dengan standar yang dapat dibaca oleh tim *IT Operations* dan Manajemen.

- **Tugas Teknis:** Buat Matriks Prioritas Mitigasi yang komprehensif.
- **Output Laporan:** Tabel matriks harus memuat:
 1. Nama Kerentanan & CVE ID (jika ada).
 2. Tingkat Risiko (CVSS Score).
 3. Bukti Validasi (*True Positive*).
 4. Rekomendasi Mitigasi Taktis (Langkah teknis perbaikan).
 5. Rekomendasi Mitigasi Strategis (Perubahan konfigurasi jangka panjang).

Jawaban:

Matriks Prioritas Mitigasi

Berdasarkan hasil vulnerability scanning menggunakan Nessus, ditemukan tujuh kerentanan dengan tingkat risiko Critical dan High yang menjadi prioritas mitigasi. Hasil Nessus menunjukkan lima temuan Critical dan dua temuan High. Sementara itu, hasil Nmap NSE digunakan sebagai metode pembandingan dan validasi awal.

No.	Nama Kerentanan & CVE ID	Tingkat Risiko (CVSS)	Bukti Validasi / True Positive	Rekomendasi Mitigasi Taktis	Rekomendasi Mitigasi Strategis
1	Canonical Ubuntu Linux SEoL (8.04.x) — CVE: tidak dicantumkan pada laporan	Critical — 10.0	Tervalidasi oleh Nessus sebagai temuan Critical , tetapi belum ada validasi manual True Positive pada laporan. Sistem terdeteksi menggunakan Ubuntu 8.04 yang sudah End of Life.	Segera upgrade/migrasikan sistem operasi ke Ubuntu versi yang masih mendapatkan security update. Jika migrasi belum dapat dilakukan, isolasi host dari jaringan yang tidak diperlukan dan batasi akses hanya dari host yang dipercaya.	Terapkan lifecycle management sistem operasi. Tetapkan kebijakan bahwa OS yang telah EoL tidak boleh digunakan pada lingkungan produksi dan lakukan patch management serta asset inventory secara berkala.

2	VNC Server 'password' Password — CVE: tidak dicantumkan pada laporan	Critical — 10.0	Tervalidasi oleh Nessus sebagai Critical berdasarkan penggunaan password bawaan/lemah. Validasi login manual belum dicantumkan.	Ganti password VNC dengan password kuat dan unik. Nonaktifkan VNC jika tidak diperlukan. Batasi akses VNC menggunakan firewall/VPN dan jangan mengeksposnya langsung ke jaringan yang tidak dipercaya.	Terapkan kebijakan password yang kuat, MFA bila didukung, network segmentation, dan privileged-access management. Lakukan audit terhadap seluruh remote-access service secara berkala.
3	Apache Tomcat AJP Connector Request Injection (Ghostcat) — CVE: tidak dicantumkan pada laporan	Critical — 9.8	Terdeteksi Nessus sebagai Critical. Belum ada validasi manual True Positive dalam laporan.	Upgrade Tomcat ke versi yang telah diperbaiki. Jika AJP tidak diperlukan, nonaktifkan AJP Connector. Jika tetap diperlukan, batasi akses AJP hanya dari host yang memang membutuhkan.	Terapkan patch management untuk middleware/web server, lakukan service minimization, network segmentation, dan review konfigurasi AJP secara berkala.
4	SSL Version 2 and 3 Protocol Detection — CVE: tidak dicantumkan pada laporan	Critical — 9.8	Terdeteksi Nessus sebagai Critical karena penggunaan protokol SSL lama. Belum ada validasi manual True Positive pada laporan.	Nonaktifkan SSLv2 dan SSLv3 pada service terkait. Gunakan protokol TLS modern yang masih didukung dan konfigurasi cipher suite yang aman.	Terapkan standar konfigurasi TLS perusahaan, lakukan hardening seluruh service yang menggunakan enkripsi, serta lakukan pemeriksaan konfigurasi TLS secara berkala.

5	Bind Shell Backdoor Detection — CVE: tidak dicantumkan pada laporan	Critical — 9.8	Terdeteksi Nessus sebagai Critical karena ditemukan indikasi backdoor yang menyediakan akses shell tanpa autentikasi. Perlu validasi manual untuk memastikan True Positive.	Identifikasi service/port yang menyediakan bind shell, hentikan service tersebut, tutup port pada firewall, dan investigasi proses yang terkait. Jangan hanya menutup port sebelum sumber backdoor diperiksa.	Terapkan host hardening, application allowlisting, network segmentation, continuous monitoring, serta proses incident response untuk setiap indikasi backdoor.
6	Samba Badlock Vulnerability — CVE: tidak dicantumkan pada laporan	High — 7.5	Terdeteksi Nessus sebagai High pada layanan Samba. Belum terdapat validasi manual True Positive dalam laporan.	Update Samba ke versi yang telah mendapatkan patch keamanan. Batasi akses SMB/Samba hanya ke host atau subnet yang membutuhkan dan tutup port SMB yang tidak diperlukan.	Terapkan patch management untuk file-sharing service, segmentasi jaringan, prinsip least privilege, dan audit akses SMB secara berkala.
7	NFS Shares World Readable — CVE: tidak dicantumkan pada laporan	High — 7.5	Terdeteksi Nessus sebagai High karena share NFS dapat dibaca secara terbuka. Validasi manual hak akses belum dilakukan dalam laporan.	Periksa export NFS dan hapus akses yang tidak diperlukan. Batasi client yang dapat mengakses share dan ubah permission agar hanya user/group yang berwenang yang dapat membaca data.	Terapkan prinsip least privilege, access control berbasis kebutuhan, segmentasi jaringan untuk layanan NFS, serta audit permission dan export configuration secara berkala.

Prioritas Mitigasi

Berdasarkan skor CVSS, urutan prioritas penanganan adalah:

1. Canonical Ubuntu Linux SEoL — CVSS 10.0

2. VNC Server 'password' Password — CVSS 10.0
3. Apache Tomcat AJP Connector Request Injection (Ghostcat) — CVSS 9.8
4. SSL Version 2 and 3 Protocol Detection — CVSS 9.8
5. Bind Shell Backdoor Detection — CVSS 9.8
6. Samba Badlock Vulnerability — CVSS 7.5
7. NFS Shares World Readable — CVSS 7.5

Catatan Validasi

Status pada kolom *Bukti Validasi (True Positive)* perlu dibedakan dari hasil deteksi otomatis. Nessus telah mengidentifikasi temuan-temuan tersebut, tetapi hasil scanner belum otomatis membuktikan bahwa seluruh temuan merupakan True Positive. Pada Misi No. 4, satu kerentanan Critical/High harus divalidasi melalui interaksi manual sebelum dapat dinyatakan sebagai True Positive secara lebih kuat.

Hal ini juga konsisten dengan hasil Nmap NSE. Pada Apache 2.2.8, NSE menemukan sejumlah referensi vulnerability dengan skor hingga 10.0 dan 9.8 melalui database Vulners, tetapi laporan menyatakan bahwa hasil tersebut merupakan indikasi berbasis versi/CPE dan belum dapat langsung dianggap sebagai bukti eksploitabilitas.